Zach Calvert

Fort Worth, TX www.linkedin.com/in/zachcalvert

Principal Security Analyst

SUMMARY

Principal Application Security Leader with 22+ years of software engineering expertise and proven success designing enterprise-grade CI/CD pipelines. Adept at migrating and consolidating AppSec toolchains, including transitioning enterprise scanning utilities from Veracode to GitHub Advanced Security (SAST/SCA) and OWASP ZAP (DAST) for over 14,000 code repositories. Well versed in Application Security Posture Management. Recognized for innovating IaC security solutions including provisioning Terraform managed environments for BugCrowd penetration testing engineers, supporting an internal Vulnerability Disclosure Program. Skilled in driving cross-functional alignment between security, DevOps, and engineering teams to build resilient, secure software ecosystems.

PROFICIENCIES

- *Application Security Posture Management (ASPM):* GitHub Advanced Security, JFrog Curation (SSCS), Threat Modeling (STRIDE), DAST, Okta/OIDC, Veracode, CyberArk, BugCrowd, SAST, SCA, Claude Security, VulnHunter
- *Cloud Security:* Imperva WAF, Hadrian External Attack Surface Management (EASM), Wiz Cloud Security Posture Management (CSPM), Prisma Cloud, Twistlock/Checkov
- *Cloud Engineering:* Azure, AWS, GCP, Pivotal Cloud Foundry, Kubernetes/AKS/EKS, OpenShift, Swarm, Terraform/IaC, Disaster Recovery, Entra AD (IAM)
- *AI:* Microsoft Copilot, Claude Code, Claude Security, Google Gemini, Azure Databricks Genie AI, Model Context Protocol (MCP)
- *DevOps:* GitHub Actions, Terraform, Azure Resource Management (ARM), Claude Code, Docker, Kubernetes, Swarm, JFrog Artifactory, Gitlab, Jenkins, Vagrant, Ansible, GitFlow, Jira, BitBucket, Bamboo, Gradle, Subversion
- *Compliance:* OneTrust GRC, LeanIX, ServiceNow, PCI DSS, HIPAA, SOX, SOC, SailPoint
- *Cybersecurity:* NIST Cybersecurity Framework, TLS, OWASP Top 10, JWT/OIDC, Splunk SIEM, Palo Alto XSIAM, Keyfactor, Bugcrowd, Checkmarx ZAP
- *Eventing and NoSQL services:* Kafka, Azure Event Hubs, Cassandra, Redis, MongoDB, Azure Databricks, MQTT, RabbitMQ, ActiveMQ, Tibco, 12 Factor Applications, CAP Theorem, Event Driven/Saga, Open API
- *SQL:* Oracle, MySQL, PostgreSQL, MS SQL Server
- *Python:* Azure Databricks, Flask
- *Java:* Spring Boot Microservices, Unit, JMockit, Hibernate, Camel, Gradle, OSGi, JDBC, Apache Tomcat, Apache ServiceMix, Maven, Groovy, Spock
- *Golang:* Gin Microservices, CLI utilities, CGO
- *JavaScript:* ReactJS, NPM, Yarn, Bootstrap 4, NextJS

EXPERIENCE

McKesson Principal Security Analyst *Oct 2022- Sept 2026*

Principal Information Security Analyst coordinating code security efforts for over 3,000 engineers at McKesson including a Veracode to GitHub Advanced Security migration, JFrog Curation adoption for Software Supply Chain Security (SSCS), metric capturing for KPI observations and application health including extracting data from Hadrian, Wiz, LeanIX, ServiceNow, and GitHub. Served as Cybersecurity engineering lead during engagements triggered by disclosures from BugCrowd Vulnerability Disclosure Program.

- *Software Supply Chain Security:* Delivered JFrog Curation to protect the business from compromised dependencies and provide Software Supply Chain Security (SSCS). Coordinated procurement, ZSCaler networking controls, and change management. Engaged with the SIEM team for log data ingestion as part of NIST Detect efforts. Enforced network intercepts using ZScaler for npm, golang, rust, and rubygems.

- *Shai Hulud Threat Response:* Provided strategic leadership directly to business unit leads, engineering leads, and presented at multiple town halls regarding ongoing Shai Hulud NPM supply chain attacks. Personally updated Cybersecurity managed GitHub repositories to lead by example in incorporating JFrog Curation and adopt package locking best practices. Prepared JFrog Curation adoption demoware for Python, Java, Javascript NPM, and Golang.

- *Cybersecurity AI Adoption:* Engaged Anthropic for early access to Claude Security code scanning. Worked directly with engineering teams to produce data flow diagrams (DFD) and performed STRIDE threat modeling for context preparation. Performed scans against existing services while capturing cost model evaluations. Delivered feedback regarding context retention and false positive findings. Performed Claude Opus scans using VulnHunter for comparison regarding findings and skill output.

- *Enterprise AppSec Migration & DevSecOps Standardization:* Reduced tooling cost and improved mean-time-to-remediate (MTTR) code security by executing the migration of Veracode SAST, SCA, and DAST to GitHub Advanced Security adoption for over 14,000 repositories. Replaced Veracode DAST with ZAP DAST including custom plugins for credential and exposed private key detection. Delivered reusable GitHub Actions Workflows, internal documentation and video training. Constructed data pipelines capturing alert types, severity, and age for executive discussion, audits, and compliance team engagements to Azure Databricks complete with Genie AI for natural language support for audit and compliance teams.

- *BugCrowd VDP (Penetration Testing Automation):* Delivered VM provisioning using Terraform IaC with GitHub Action pipelines for BugCrowd penetration testers to be assigned Kali Linux VMs managed within the McKesson network. Observability and threat controls in place coordinated across teams including Network Security, Cyber Detect and Hunt, and Incident Management. Automated BugCrowd data pipelines of campaign KPIs for executive monitoring.

- *Attack Surface Management & Domain Ownership Platform:* Conceived, architected, and deployed a Kubernetes-hosted Application Security Posture Management (ASPM) engine to establish clear accountability and escalation paths across 15,000+ cloud-hosted domains. Created Python data integrations retrieving data from Wiz (CSPM), ServiceNow, Hadrian (EASM), LeanIX, OneTrust (GRC), and GitHub for building a complete perspective on accountability. Delivered a custom ReactJS / Python Flask interface (utilizing AI-assisted development via Claude Code) enabling instant query capabilities for security analysts during critical incidents.

- *Enterprise Compliance Observability:* Engaged with internal audit, Cybersecurity, and compliance teams to coordinate capture of application KPIs in Azure Databricks, fed by Azure Data Factory into a PowerBI dashboard. Constructed internal GitHub Application to extract all SAST, SCA, and secret findings for audit oversight including Genie AI for natural language querying and compliance audit report generation.

- *Application Compliance Automation:* Delivered CI/CD custom GitHub Action for capturing pass/fail compliance state on repository health as part of CI/CD gating. Used GitHub's OIDC for repository identification with custom GitHub Application for interacting with GitHub's APIs for open repository alerts, severity, and age evaluation.

- *Detect and Hunt - SIEM:* Orchestrated JFrog and GitHub log event delivery to Palo Alto XSIAM for Cybersecurity Detect and Hunt efforts. Provided Cortex Query Language (XQL) queries to identify activity leading to identified compromised user accounts, exposed Personal Access Tokens (PATs) and malicious adversaries.

- *OneTrust Audit Automation:* Reduced deployment gaps in compliance assessment by implementing OneTrust GRC automation for compliance teams. Consumed data from Azure Databricks identifying new application launches and hostname exposures to trigger internal audit and compliance assessments. Automated services launch OneTrust assessments, create Jira tickets for assessment status monitoring, and summary emails delivered via SendGrid for auditor notifications.

Signify Health Staff Engineer *Jan 2022- Oct 2022*

- Architected next-generation CI/CD security and delivery pipelines on AWS EKS using GitHub Actions and Terraform (IaC), accelerating healthcare application deployment velocity while establishing secure cloud-native deployment patterns.

- Streamlined cloud infrastructure provisioning to enforce standardized deployment guardrails, container security, and environment consistency across engineering teams.

Workforce @ Toyota Senior Software Engineer *Jan 2021- Dec 2021*

- Engineered automated security testing utilities and remote hardware instrumentation for vehicle Electronic Control Units (ECUs), enabling cross-continental automated penetration and security verification.

- Architected distributed Golang microservices on Kubernetes to interface with physical device hardware probes via remote-control protocols across global networks.

HCL @ BNSF Railway Senior Software Engineer *Feb 2017 - Dec 2020*

- Designed resilient Java Spring Boot microservices and API gateways powering enterprise crew-coordination mobile applications for field operations.

- Improved system efficiency and operational security by building real-time telemetry and location tracking integrations, relieving high-volume call center dependencies.

Spireon Senior Java Developer *July 2016 - Feb 2017*

- Architected geo-locational IoT asset recovery services, engineering secure IoT device identity caching mechanisms that reduced compute overhead and device latency.

TEKsystems @ SWA DevOps Engineer *Mar 2016 - July 2016*

- Automated manual deployment, reducing duration from 6 hours to minutes, eliminating deployment errors, and saving significant operational headcount costs.

Xpressdocs Senior Software Developer *July 2015 - Mar 2016*

- Led organizational transition from Waterfall to Agile/DevOps practices, reducing issue Mean-Time-to-Remediate (MTTR) and significantly boosting release delivery velocity.

Alcatel-Lucent Senior Software Developer *Jun 2009 - Apr 2015*

- Delivered telecommunications, mobile endpoint management, and smart-metering network solutions using Java.

TransUnion Junior Software Developer *Jan 2005 - Apr 2009*

- Developed automated real-time property valuation and flood research algorithms for credit reporting and real estate systems.

EDUCATION

University of Texas at Arlington *Jan 2000 - Dec 2004*
Graduated summa cum laude with a Bachelor of Science in Software Engineering.

Online Courseware
Linux Academy: Docker - Deep Dive
Linux Academy: Using Terraform to Manage Applications and Infrastructure
Udemy: AWS Certified Developer - Associate 2019
Udemy: AWS Serverless APIs & Apps - A Complete Introduction
Udemy: Docker Mastery: The Complete Toolset From a Docker Captain
Udemy: JavaScript: Understanding the Weird Parts
Udemy: Vim Masterclass
Udemy: Learn DevOps: Infrastructure Automation with Terraform
Udemy: Learn DevOps: The Complete Kubernetes Course
Udemy: Getting Started with Apache Cassandra
Mongo University: MongoDB for Java: 101